

Secure Deployment of Containerized Node.js Application on Google Cloud using DevSecOps Principles

Prepared By: Dhinesh Kumar

Platform: Google Cloud Platform (GCP)

Implementation: Terraform + GitHub Actions + Cloud Run

1. Project Objective

This project demonstrates a secure DevSecOps implementation for deploying a containerized Node.js REST API on Google Cloud. Infrastructure is provisioned using Terraform, CI/CD is automated with GitHub Actions, authentication uses Workload Identity Federation (OIDC), secrets are managed using Secret Manager, and the application is deployed to Cloud Run with a private Cloud SQL backend.

2. Solution Overview

The application is packaged as a Docker container and deployed to Cloud Run. Cloud SQL (MySQL) is accessible through a Serverless VPC Access Connector over a private IP. Terraform provisions all infrastructure resources. GitHub Actions performs automated validation, testing, image creation, and deployment.

3. Technologies Used

- Node.js & Express.js
- Docker
- Google Cloud Run
- Cloud SQL (MySQL)
- Artifact Registry
- Secret Manager
- Terraform
- GitHub Actions
- OIDC (Workload Identity Federation)
- Cloud Monitoring & Cloud Logging

4. Infrastructure Provisioned

- VPC Network & Subnet
- Private Service Networking
- Serverless VPC Access Connector
- Cloud SQL Instance
- Database & User
- Secret Manager Secret
- Artifact Registry
- Cloud Run Service
- IAM Service Accounts & Roles
- Monitoring Resources

5. CI Pipeline

The CI pipeline automatically performs:

- ESLint
- Jest Unit Tests
- npm audit
- Docker Build
- terraform fmt
- terraform validate
- TFLint

6. CD Pipeline

The CD pipeline authenticates using OIDC, builds a Docker image, pushes it to Artifact Registry, and deploys the latest revision to Cloud Run automatically.

7. Security Implementation

- Principle of Least Privilege IAM
- No Service Account JSON Keys
- OIDC Authentication
- Secret Manager Integration
- Private IP Cloud SQL
- Serverless VPC Connector
- Infrastructure as Code

8. Monitoring & Logging

Cloud Logging collects application logs. A logs-based metric and monitoring alert policy are configured. Email notification is configured for operational alerts.

9. Validation

Completed successfully:

- Terraform Validation
- Cloud Run Deployment
- Cloud SQL Connectivity
- GitHub Actions CI
- GitHub Actions CD
- Docker Build
- Secret Manager Integration

10. Future Enhancements

- Google Chat notifications
- Trivy image scanning
- Binary Authorization
- Remote Terraform State
- Multi-environment deployment

11. Conclusion

The project successfully implements a secure, automated, and scalable DevSecOps deployment pipeline on Google Cloud using modern cloud-native services and security best practices.